

PRIVACY POLICY AND DATA PROTECTION

Telematic Medical Applications LTD (“TMA”) has developed the ePokratis MedAiConnect application (the “Application”). Through the Application, users may: (i) receive and automatically record vital-sign measurements from compatible Bluetooth medical devices, (ii) perform AI-based measurements via the mobile device’s camera (including Stress Level, Pulse Rate, Respiratory Rate, Oxygen Saturation (SpO₂), and Blood Pressure (BP)), (iii) manually log data from non-compatible devices, (iv) upload digital files or test results, (v) communicate with healthcare professionals affiliated with TMA, and (vi) receive medical advice, as detailed in the Terms of Use.

AI-Generated Measurements

Scope and purpose. The Application provides AI-generated measurements for Stress Level, Pulse Rate, Respiratory Rate, Oxygen Saturation, and Blood Pressure. These AI measurements are strictly informational and wellness-oriented. They are not designed or approved for clinical use, diagnosis, treatment, or medical decision-making and must not be used in emergencies. The Application is not a medical device. Always consult a licensed healthcare professional for medical advice.

On-device processing and media handling. AI processing occurs locally on your device. No images or videos captured for AI analysis are uploaded to or stored on our servers, and we do not retain the facial video or images used during analysis.

Saving and syncing of AI measurement results. The numeric results (e.g., Pulse Rate in bpm, Respiratory Rate in breaths/min, Oxygen Saturation in %, Blood Pressure in mmHg, Stress Level index) produced by AI are saved to your in-app measurement history and synced to your account so you can view them across your signed-in devices. Each saved entry clearly indicates its source: “AI,” “Device,” or “Manual.” For device-sourced entries, the device name/model used for the measurement is also recorded and shown. Selected metrics, such as Blood Pressure and Heart Rate, are displayed in charts within the Application. Charts and trends are for visualization only and are not diagnostic tools. (See Display of measurements for charting rules.) You may delete individual measurements from your history at any time (deletions sync across your signed-in devices). See Data Retention and Deletion for account-level deletion.

Accuracy constraints. AI measurements can be affected by lighting, motion, camera quality, skin tone, occlusions, and individual physiology. Results are

approximate and may vary. For best results, follow in-app guidance and remain still in a well-lit environment.

Availability. Camera-based measurements are available only on supported devices and under suitable conditions (e.g., adequate lighting). See the app's store listing for current compatibility details.

Device-sourced vs AI-generated (Blood Pressure and Oxygen Saturation).

- **Compatible devices (recommended for reliability).** When you pair compatible Bluetooth medical devices, measurements (e.g., Blood Pressure, Oxygen Saturation, Heart Rate) shown in the app originate from the external device and are saved to your history with the “Device” source label. Each entry also displays the device name/model used.
- **AI Blood Pressure / Oxygen Saturation (units shown).** When you use camera-based AI Blood Pressure and/or Oxygen Saturation, results are displayed with their customary units (Blood Pressure in mmHg; Oxygen Saturation in %) and saved with the “AI” source label. These values remain non-medical wellness estimates and may be imprecise; they are not a substitute for measurements from compatible devices or professional care.
- **Regulatory status.** These camera-based features are not medical devices (e.g., a pulse oximeter or blood pressure monitor) and are not intended to diagnose, treat, cure, mitigate, or prevent any disease or condition.

Personal Data Processing and Storage

Personal data you provide—either (a) with your explicit consent or (b) because it is necessary to enter into or perform the contract between you and TMA (for example, to create and manage your account and deliver the features you request)—is processed by TMA and hosted on servers operated by Hetzner Online GmbH (Germany, EU/EEA) under a GDPR-compliant Data Processing Agreement. TMA acts as the data controller for the processing described in this Policy (clinicians act as independent controllers for their clinical records). Data is encrypted in transit (HTTPS/TLS) and encrypted at rest using application-layer AES-256. As stated above, camera images/video used for AI analysis are processed on your device and are neither uploaded to nor stored on our servers.

TMA may grant strictly limited, need-to-know access to:

- Healthcare professionals contracted with TMA whom you choose to engage (acting as independent controllers), solely to provide the teleconsultation you request; and
- Sub-processors (such as Hetzner and RevenueCat (subscription management)) that process personal data only on TMA's documented instructions, under GDPR-compliant data processing agreements.

Third-party sign-in and infrastructure. If you choose Google Sign-In or Facebook Login, your authentication data is handled by Google or Meta (Facebook) to provide their sign-in services, subject to their own privacy policies. We also use Google Firebase services—primarily Firebase Authentication and, where enabled, Crashlytics and Performance Monitoring—to operate and secure the Application. These services may receive limited device and diagnostic information (e.g., app version, device model, crash logs) to help us troubleshoot and improve stability. (Apple Sign-In applies on iOS; not used on Android.)

International data transfers. Our primary hosting is in the EU/EEA (Hetzner). Some service providers (e.g., Google/Firebase and Meta/Facebook for sign-in and app infrastructure, RevenueCat) may process personal data in countries outside the EU/EEA (for example, the United States). Where this occurs, we ensure a lawful transfer mechanism is in place (e.g., the European Commission's Standard Contractual Clauses and, where applicable, the UK International Data Transfer Addendum) and apply appropriate safeguards such as encryption, strict access controls, and data minimization. Where required by law, we will obtain your consent or provide additional notice.

Global availability. The Application is offered in multiple countries and regions. This does not change our primary hosting location in the EU/EEA or our data-protection commitments. Depending on where you live, you may have specific privacy rights under local law.

TMA is a Greek company, registered under the General Commercial Registry (G.E.MI.) No. 007904401000, with Tax Identification Number (TIN) 998889850. Registered address: 151 Al. Papanastasiou Avenue, Piraeus, Attica, 18533, Greece. Contact: +30 211 1165330-2, info@tma.gr.

Personal data is processed only for the purposes described in this Privacy Policy and in accordance with applicable data-protection laws, including the GDPR.

User Support and Inquiries

If you have questions about how your personal data is stored or protected, if you wish to exercise your data-protection rights (such as access, rectification, portability, restriction, objection, deletion, or withdrawal of consent), or if you want to file a complaint, please contact our Data Protection Officer (DPO).

Primary contact (DPO): dpo@tma.gr

Postal: Data Protection Officer, Telematic Medical Applications LTD, 151 Al.

Papanastasiou Avenue, 18533 Piraeus, Attica, Greece

General support: info@tma.gr

We may request information to verify your identity before responding. We aim to respond within one month of receipt of your request (this period may be extended by two further months where necessary, considering the complexity and number of requests).

If you believe your rights have not been respected, you may lodge a complaint with the Hellenic Data Protection Authority (HDPa): +30-210-6475600, Kifisias 1-3 Avenue, 115 23 Athens, contact@dpa.gr.

The latest Privacy Policy for the ePokratis MedAiConnect application is available at: <https://tma.gr/epokratis-privacy-policy-android-en/>

Data Protection Oversight

TMA has designated a Data Protection Officer (DPO) in accordance with GDPR Articles 37–39. The DPO (i) monitors compliance with data-protection laws and this policy, (ii) advises on data-protection impact assessments where required, and (iii) acts as the contact point for supervisory authorities, including the Hellenic Data Protection Authority (Article 39(1)(e)).

Per Article 38(4), you may contact the DPO about the processing of your personal data and the exercise of your rights:

Email: dpo@tma.gr

Postal: Data Protection Officer, Telematic Medical Applications LTD, 151 Al.

Papanastasiou Avenue, 18533 Piraeus, Attica, Greece.

The DPO performs duties independently and handles inquiries confidentially.

User Consent

By submitting your personal data through the Application, you acknowledge that you have read, understood, and accepted this Privacy Policy. Where required, we obtain

your explicit consent via an opt-in action at sign-up. This consent covers the processing (including storage) of your personal and health data—including measurements from compatible devices and AI-derived estimates—as described in this Privacy Policy and the Application’s Terms of Use. In certain flows, you may also provide consent for optional features you choose to use (e.g., Send Location) or manage specific consents in Settings (e.g., Manage SSN Consent).

Some processing also takes place under other lawful bases—for example, to perform the contract with you (create and manage your account, sync your history, enable teleconsultations and doctor-session/device purchases, and deliver the features you request) and to meet legal obligations (e.g., invoicing and record-keeping under applicable law). Withdrawing consent does not affect the lawfulness of processing carried out before the withdrawal.

You may withdraw specific consents at any time in Settings (e.g., Manage SSN Consent) or by not using optional features that rely on consent (e.g., choosing not to tap Send Location). To stop further processing and remove server-stored data, use the in-app account deletion flow (subject to any legally required retention).

Uninstalling the Application alone does not delete your account or data stored on our servers.

Accuracy of Provided Data

Users are responsible for ensuring that the information they provide through the Application is accurate, complete, and up to date. Users can review and update their details in Settings at any time and retain the right to rectification under applicable data-protection laws.

To the extent permitted by applicable law, TMA is not responsible for issues arising from false, incomplete, or outdated information provided by users. TMA may seek compensation for losses caused by fraudulent or unlawful information, without prejudice to users’ mandatory statutory rights.

1. Legal Bases for Processing Personal Data

We process your personal data on the following legal bases:

- **Contract (GDPR Art. 6(1)(b)):** to create and manage your account, deliver the features you request (including syncing your measurement history), provide teleconsultation services you choose to use, and facilitate purchases you initiate (doctor sessions or medical devices) via our TMA-managed e-shops, as necessary to perform our agreement with you. For

health data, we rely on Art. 6(1)(b) (to provide the service) together with Art. 9(2)(a) (your explicit consent).

- **Consent (GDPR Art. 6(1)(a)):** where you give explicit consent (e.g., at sign-up) to process special-category health data, including AI-derived estimates, and for optional features you choose to enable (such as Send Location and other options described in this policy or at the point of collection). You may withdraw consent at any time by using in-app controls where available, revoking device permissions in your operating system settings (e.g., Location for Send Location), or by not using the optional feature; withdrawal does not affect the lawfulness of processing before withdrawal.
- **Legal obligation (GDPR Art. 6(1)(c)):** to comply with obligations under applicable law (e.g., invoicing/tax and mandatory record-keeping). In some jurisdictions (e.g., Greece for doctor sessions), this may require collecting a national identifier (e.g., SSN or local equivalent) to enable affiliated clinicians to issue prescriptions and, for device purchases, to allow the TMA e-shop to issue official tax/insurance invoices or receipts where an identifier is required by law.
- **Legitimate interests (GDPR Art. 6(1)(f)):** to help prevent fraud and abuse and to maintain the security and integrity of the service, balanced against your rights and freedoms. We do not rely on legitimate interests for special-category (health) data or for marketing. You may object to processing based on legitimate interests at any time (GDPR Art. 21).

Special-category data (health)

We process health data only when one of the following applies:

- **Your explicit consent** (GDPR Art. 9(2)(a)); or
- **Provision of health care by licensed professionals** subject to confidentiality, where processing is necessary to deliver the teleconsultation you request (GDPR Art. 9(2)(h), subject to applicable local law). For video consultations, only the minimum necessary health data is processed to enable the clinician to provide the service.
- **Clarifier:** The AI-generated wellness estimates (e.g., Stress Level, Pulse Rate, Respiratory Rate, Oxygen Saturation, Blood Pressure) relate to your physiological state and—although non-clinical and approximate—are treated as health data under GDPR. We process and sync these values to your account (so you can view them across your signed-in devices) on the basis of your explicit consent (GDPR Art. 9(2)(a)). Article 9(2)(h) applies only

to processing performed by affiliated clinicians to deliver teleconsultations under professional secrecy.

National Identifiers (e.g., SSN) and purchase flows

At sign-up and in profile settings, providing a national identifier (e.g., SSN or local equivalent) is optional. However, before completing a purchase within the Application (doctor sessions or medical devices), you will be prompted to provide your SSN, subject to local law. Purchases are completed on TMA-managed e-shops; the Application redirects you to the relevant e-shop checkout after this step.

Doctor sessions.

- **Where required by law** (e.g., Greece): processing is based on legal obligation (Art. 6(1)(c)) and, as applicable, contract (Art. 6(1)(b)), so that affiliated clinicians can issue prescriptions/medical records and the transaction complies with local requirements.
- **Where not required by law:** we still prompt for SSN as a condition of purchase for identity verification, fraud prevention, and to enable appropriate clinical documentation and after-sales support, subject to local law. Processing is based on contract (Art. 6(1)(b)) and legitimate interests (Art. 6(1)(f)). If you do not provide an SSN, the purchase cannot be completed via the in-app flow; you may contact support for alternatives where permitted by local law.

Medical devices.

Before redirecting you to the TMA device e-shop, you will be prompted to provide your SSN (or local equivalent). We collect this identifier to (i) issue official tax/insurance invoices or receipts where required by law (e.g., to support reimbursement by a local health system) and (ii) verify identity, prevent fraud, and enable official documentation upon request, subject to local law.

- **Legal basis:** where an identifier is legally required for invoicing/receipts, processing is based on legal obligation (GDPR Art. 6(1)(c)); otherwise, processing is based on contract (Art. 6(1)(b)) and legitimate interests (Art. 6(1)(f)). You may object to processing based on legitimate interests at any time (GDPR Art. 21).
- If you do not provide an SSN, the purchase cannot be completed via the in-app flow; you may contact support for alternatives where permitted by local law.

- Official invoices/receipts for device purchases are issued by the TMA e-shop.

Purpose limitation and security

Your national identifier (e.g., SSN or local equivalent) is used only for the purposes described above: (i) enabling affiliated clinicians to issue prescriptions/medical records where required by law, (ii) issuing official tax/insurance invoices or receipts where required by law, and (iii) identity verification and fraud prevention to protect accounts and transactions. It is encrypted in transit (HTTPS/TLS) and at rest (application-layer AES-256), access is strictly limited on a need-to-know basis, and it is not used for advertising or analytics. We retain it only as long as necessary for these purposes and legal obligations, then delete or anonymize it.

Managing your SSN

Your national identifier (e.g., SSN or local equivalent) is securely stored and strictly used only for the purposes described above. You can request deletion of your SSN and withdraw any consent you have given at any time via Settings → “Manage SSN Consent.” If you remove or do not provide an SSN, you will be unable to complete purchases via the in-app flow (doctor sessions and medical devices). This does not affect the lawfulness of processing carried out before withdrawal. A national identifier is not required for subscription purchases made via Google Play. Where we must retain SSN data to comply with legal obligations, to keep transaction records under a contract with you, or for the establishment, exercise, or defense of legal claims, we will retain it for the applicable statutory or limitation period and then delete or anonymize it. If any SSN processing relies on legitimate interests (e.g., fraud prevention and account security), you may object at any time (GDPR Art. 21).

2. Collected Data

2.1. Information Directly Provided by Users in the ePokratis MedAiConnect Application

We collect personal data that you choose to submit when you use the Application’s features (with your explicit consent or as necessary to provide the services you request). This includes:

- Account and profile details (name, email, phone, date of birth, gender; optional height/weight, allergies, medical/surgical history, current medications). This information helps healthcare professionals contracted with TMA contextualize symptoms and provide informed feedback during consultations.

- Health and wellness information you enter or generate, including measurements from compatible Bluetooth medical devices and AI-based measurements (Stress Level, Pulse Rate, Respiratory Rate, Oxygen Saturation, Blood Pressure). Numeric results are saved to your history and synced to your account; each entry shows its source (“AI”, “Device”, or “Manual”). For device-sourced entries, the device name/model is shown. Camera images/video used for AI analysis are processed locally on your device and are not uploaded or stored. You may delete individual measurements from your history at any time (see Data Retention and Deletion).
- Documents and files you upload (e.g., lab results, medical reports).
- Appointment and teleconsultation details you provide and scheduling information (date/time, specialty, doctor’s name). Content you share during a consultation is provided to the healthcare professional you select via TMA’s secure platform.
- National identifiers (e.g., SSN) when prompted during purchase flows, as described in “National Identifiers (e.g., SSN) and purchase flows.”
- Messages you send to TMA or to clinicians, and any attachments you choose to upload.

We collect this information only when you take an action that provides it (for example, starting a measurement, pairing a device, uploading a document, booking/purchasing, contacting support, or updating your profile). We do not store camera images or videos from AI measurements, and we do not collect personal data for advertising purposes. We do not collect personal data unrelated to providing or securing the service during general navigation. Certain limited device and diagnostic data (e.g., app version, device model, crash logs) may be collected automatically to maintain security and troubleshoot issues, as described under “Third-party sign-in and infrastructure.”

The ePokratis MedAiConnect application does not perform medical analysis, diagnosis, or treatment based on the provided data. It facilitates secure communication and information exchange between you and healthcare professionals. When you use the video call service, you explicitly consent to share text, audio, video, and/or photos with the selected healthcare professional.

Social Security Number (SSN) / National Identifiers

- At sign-up and in profile settings, providing a national identifier (e.g., SSN or local equivalent) is **optional**.
- Before completing a purchase from within the Application (doctor sessions or medical devices), you will be prompted to provide a national identifier (subject to local law). If you do not provide one, the purchase cannot be completed via the in-app flow. After this step, you are redirected to a TMA-managed e-shop to complete checkout.

Why we ask

- **Doctor sessions:** in some jurisdictions (e.g., Greece), a national identifier is required by law so affiliated clinicians can issue prescriptions/medical records and compliant receipts.
- **Medical devices:** a national identifier may be required by law to issue official tax/insurance invoices/receipts. Where not required by law, we use it for identity verification, fraud prevention, and to enable official documentation upon request, subject to local law.

Legal basis

- Where required by applicable law: legal obligation (GDPR Art. 6(1)(c)).
- Where not required by law: contract (Art. 6(1)(b), as a condition of purchase) and legitimate interests (Art. 6(1)(f)) for identity verification, fraud prevention, and issuing documentation upon request. You may object to processing based on legitimate interests at any time (GDPR Art. 21).

If you do not provide a national identifier

- The purchase of doctor sessions or devices cannot be completed via the in-app flow; you may contact support for alternatives where permitted by local law.

Storage and security

- National identifiers are encrypted in transit (HTTPS/TLS) and at rest (application-layer AES-256), access is strictly limited, and they are not used for advertising or analytics.
- Where necessary to fulfil your request, identifier details may be shared with the healthcare professional you choose to engage (to issue

prescriptions/medical records/receipts under professional secrecy) and with service providers acting on TMA's documented instructions under GDPR-compliant terms.

- Official device invoices/receipts are issued by the TMA e-shop.

Managing your SSN

- You can view/update your identifier, withdraw any consent you have given, and request deletion at any time via Settings → "Manage SSN Consent." If any SSN processing relies on legitimate interests, you may object at any time (GDPR Art. 21).
- If you remove or do not provide an identifier, you will be unable to complete purchases via the in-app flow (doctor sessions and medical devices). This does not affect the lawfulness of processing carried out before withdrawal.
- Where we must retain identifier data to comply with legal obligations, to keep transaction records under a contract with you, or for the establishment, exercise, or defense of legal claims, we will retain it for the applicable statutory/limitation period and then delete or anonymize it.

Health Data

Users can record health data in the Application through the following methods:

- **Compatible Bluetooth medical devices.** Measurements from supported devices (e.g., blood-pressure monitors, pulse oximeters, thermometers, scales, electrocardiographs, multi-parameter devices) are transferred after you pair the device and grant the required Android permissions (e.g., Bluetooth; in some cases, Nearby Devices and/or Location for scanning). Saved entries are labeled "**Device**" and show the device name/model.
- **Manual input.** You may manually enter measurements, symptoms, and other health-related information when a compatible Bluetooth device is not used. Saved entries are labeled "**Manual**."
- **Camera-based AI measurements.** Stress Level, Pulse Rate, Respiratory Rate, Oxygen Saturation (SpO₂), and Blood Pressure (BP) can be estimated using the mobile device's camera. AI processing occurs on your device; camera images/video are not uploaded or stored. Numeric results are saved to your in-app history, synced to your account, and labeled "**AI**" (units shown—for example, BP in mmHg; SpO₂ in %). These AI results are for

informational/wellness purposes only, may be approximate, and are not for diagnosis, treatment, or emergencies. Availability may depend on supported hardware and conditions (e.g., adequate lighting); see the app's store listing for compatibility. You may delete individual measurements at any time (see Data Retention and Deletion).

Use and display

- Selected metrics (e.g., Blood Pressure, Heart Rate (Pulse Rate), Weight, Glucose) may be visualized in charts within the Application for convenience and trend viewing.
- We do not use your health data for advertising, share it with third parties for their advertising/marketing, or sell personal data.

Important limitations (AI measurements)

- All AI-generated measurements (Stress Level, Pulse Rate, Respiratory Rate, Oxygen Saturation (SpO₂), Blood Pressure (BP)) are informational wellness features. They are not designed or approved for clinical use, diagnosis, treatment, or medical decision-making and must not be used in emergencies.
- Regulatory status. The camera-based features are not medical devices (e.g., a pulse oximeter or blood-pressure monitor) and do not diagnose, treat, cure, mitigate, or prevent any disease or condition.
- Accuracy constraints. Accuracy can be affected by lighting, motion, camera quality, occlusions, skin tone, and individual physiology. Follow in-app guidance and measure in a well-lit, steady setting.
- Source labeling and coexistence. AI estimates are saved with the "AI" label; device-sourced readings are saved with the "Device" label and show the device name/model. If you record both, they are stored as separate entries; AI estimates do not replace or modify device readings.
- Reliability guidance for BP/SpO₂. For Blood Pressure and Oxygen Saturation, use compatible Bluetooth medical devices for reliable values. Camera-based BP/SpO₂ are non-medical wellness estimates and may be imprecise even under good conditions.
- Units. AI outputs are shown with customary units (e.g., Blood Pressure in mmHg; Oxygen Saturation in %) and remain non-medical.

- Availability. Camera-based measurements may be available only on supported devices and under suitable conditions (e.g., adequate lighting). See the app's store listing for current compatibility details.

Purpose and consent

- Health data is collected and used to provide the features you choose (e.g., record, sync, visualize, and share during teleconsultations). Processing is based on your explicit consent (e.g., saving/syncing your measurements—including AI-derived estimates) and, for teleconsultations, on the provision of health care by licensed professionals under professional secrecy (see “Legal Bases for Processing Personal Data”).
- You may delete individual measurements from your history at any time; deletions sync across your signed-in devices. To remove your account and all server-stored data, use the in-app account deletion flow (subject to any legally required retention, as described in “Data Retention and Deletion”).

User-Provided Digital Files

Users may upload medical test results or other relevant documents in digital format through the Application. Uploaded files are stored with your account, synced across your signed-in devices, and hosted by our processor under GDPR-compliant terms (see Personal Data Processing and Storage). Data is encrypted in transit (HTTPS/TLS) and at rest (application-layer AES-256), with access restricted on a need-to-know basis.

How they're used

- Files are used only to provide the services you request (e.g., for you to view in the app or to share during a teleconsultation you initiate).
- During a consultation, only the documents you explicitly choose to share are made available to the healthcare professional you select via TMA's secure platform (clinicians are bound by professional secrecy and contractual confidentiality).
- We do not use your health data for advertising or share it with third parties for their advertising/marketing, and we do not sell personal data.

Managing and retention (uploaded files)

- Individual uploaded files cannot currently be deleted within the Application. To request deletion of specific files, please contact support or the DPO; we

will honor erasure requests where applicable under GDPR (Art. 17), except where we must retain data to comply with legal obligations or for the establishment, exercise, or defense of legal claims.

- To remove all server-stored data (including uploaded files), use the in-app account deletion flow. We will delete or anonymize your data, subject to any legally required retention (see Data Retention and Deletion).
- Access to your uploaded files is restricted to authorized TMA personnel and service providers acting on TMA's documented instructions under GDPR-compliant terms, and to the healthcare professionals you choose to share with during a teleconsultation.
- If you share a document during a consultation, the healthcare professional may retain a copy as part of their own medical record in accordance with their legal and professional record-keeping obligations; such records are controlled by the clinician/clinic, not TMA.
- Uploaded files are treated as health data. Processing is based on your explicit consent (GDPR Art. 9(2)(a)); where a clinician accesses files as part of a teleconsultation, Art. 9(2)(h) (health care by professionals under confidentiality) applies.
- Deleting your account removes all server-stored data, including uploaded files, subject to legally required retention.

Display of measurements

The five most recent measurements for Blood Pressure, Weight, Electrocardiogram (ECG)/Heart Rate, and Glucose are displayed in charts to help you monitor trends over time.

- Blood Pressure and ECG/Heart Rate: charts may include entries from all sources — “AI”, “Device”, and “Manual.”
- Weight and Glucose: charts may include entries from “Device” and “Manual.”
- Each charted entry clearly indicates its source (“AI,” “Device,” or “Manual”).

Appointment Scheduling and Teleconsultation Services Data

We process information you provide to schedule and conduct consultations (e.g., appointment date/time, medical specialty, and the healthcare professional's name), as well as limited technical/session metadata needed to set up and support the call (e.g., connection timestamps, duration, basic quality metrics).

- **Purpose.** Used solely to schedule appointments, connect you with the selected healthcare professional, and ensure service quality/troubleshooting. Not used for advertising or marketing.
- **Consultation content.** Messages/files you choose to share during a consultation are transmitted to the healthcare professional via TMA's secure platform. Healthcare professionals maintain clinical records as independent controllers under their own legal and professional obligations.
- **Recording.** TMA does not record or store audio or video of consultations.
- **Security/retention.** Access is restricted on a need-to-know basis. Session metadata is retained only as necessary for the above purposes and legal requirements; you can request account deletion in Settings (subject to legally required retention).
- **Legal bases.** Processing for scheduling and session support is based on contract (GDPR Art. 6(1)(b)) and, for quality/troubleshooting/security, legitimate interests (Art. 6(1)(f)); you may object at any time (Art. 21). Any clinical processing by the healthcare professional is carried out under GDPR Art. 9(2)(h) (health care by professionals under confidentiality).

Location Data

We collect location data only with your consent and only in connection with specific features. The app does not continuously track your location in the background.

“Send Location” (one-time)

When you tap **Send Location**, we request your explicit consent and the Android Location permission. A clear in-app notice explains the use (e.g., “*Your location helps coordinate emergency assistance to your current position*”). Once you confirm, the app transmits your device's location (precise or approximate, depending on your OS permission setting) together with a timestamp to TMA's secure servers once to help coordinate assistance. Location sharing is disabled by default, occurs only when you press **Send Location**, and is not collected in the background or without your action. You can revoke the Location permission at any time in your device's settings. This is a one-time action; no continuous tracking occurs.

“Location Sharing” (automatic, opt-in)

If you enable Location Sharing (via the consent prompt at first login or later in **Settings → Location Sharing**), the app will automatically send your device’s precise location (Android “Use precise location” must be enabled) with a timestamp only at specific in-app events:

- (a) when a vital-sign measurement is saved;
- (b) when a video call is initiated; or
- (c) when you place an emergency call via the app.

These transmissions are event-based, not continuous. You can disable Location Sharing at any time in **Settings → Location Sharing** or revoke the Location permission in your device settings.

Purpose and recipients

Location data is used solely to support your safety and care (e.g., to assist during emergencies and to provide context to the clinician you connect with). It may be accessed by healthcare professionals you choose to engage and by authorized TMA personnel/service providers acting on TMA’s documented instructions. Not used for advertising or marketing and not sold.

Control

You can disable automatic Location Sharing at any time in **Settings → Location Sharing → Deny** (in-app) and/or revoke the device’s Location permission in your OS settings. You can always use the app without enabling automatic Location Sharing.

Security and retention

Location data is encrypted in transit (HTTPS/TLS) and at rest (application-layer AES-256), with access restricted on a need-to-know basis. We retain it only as necessary for the above purposes and to meet legal requirements, after which it is deleted or anonymized.

Legal basis

Processing is based on your consent (GDPR Art. 6(1)(a)). You may withdraw consent at any time via **Settings → Location Sharing** or by revoking the device permission; withdrawal does not affect the lawfulness of processing before withdrawal.

Symptom Evaluation, Diagnosis, and Prescription Data

- **Clinician-provided content.** Any clinical assessment, diagnosis, prescription (including treatments/dosages), and related notes are provided exclusively by licensed healthcare professionals you choose to engage.
- **Role of the app.** The Application is a secure communication and relay system. It does not perform diagnoses, prescribe treatments, or provide medical advice; it only transmits/displays information the clinician provides.
- **Controller roles & legal bases.** Healthcare professionals act as independent controllers of the clinical record and process health data under GDPR Art. 9(2)(h) (health care by professionals under confidentiality) and applicable local law. TMA processes the minimum necessary data to route, display, and store items in your account to provide the service (GDPR Art. 6(1)(b), contract) and to maintain security/troubleshooting (Art. 6(1)(f); you may object at any time, Art. 21).
- **Access & retention.** Clinicians may retain copies as part of their own medical records in line with legal/professional retention rules (outside TMA's control). TMA retains any consultation metadata and artifacts stored in your account only as needed to provide the service and meet legal requirements (see Data Retention and Deletion).
- **Recording.** As noted above, TMA does not record or store audio/video of consultations.

Device, Doctor Session, and Subscription Purchase Data

Users can purchase compatible medical devices and doctor sessions through dedicated online stores managed by TMA and offered exclusively to application users.

New users receive **one free redemption unit** to try AI-based measurement sessions (including Stress Level, Pulse Rate, Respiratory Rate, Oxygen Saturation (SpO₂), and Blood Pressure (BP)).

To gain unlimited access to AI-based measurements, an active subscription is required.

Subscription purchases also provide additional benefits for doctor sessions:

- Upon **first activation** of the **Basic subscription**, the user receives **one free doctor session** — even if previously downgraded from an Advanced subscription, provided that the Basic subscription had **not been activated before**.

- Upon **first purchase or upgrade** to an **Advanced subscription**, the user receives **three free doctor sessions**.

Additionally, subscription purchases are available through the in-app purchase feature within the Application.

2.2. Information Provided Indirectly by Users

Device and diagnostic data (collected automatically)

- IP address and connection timestamp, device model, operating system and app version, push notification token (to deliver service messages/alerts), basic event and error information, and (where enabled) crash reports and performance metrics.
- **Purpose.** Operate the Application, deliver service messages/alerts, maintain security, prevent fraud/abuse, troubleshoot, and improve stability. Not used for advertising or marketing; not sold. Not used for profiling or ad personalization.
- **Tools/recipients.** May be processed by Google Firebase services—principally Authentication, Cloud Messaging (FCM) for push delivery, and, where enabled, Crashlytics and Performance Monitoring—acting on TMA’s documented instructions (see Third-party sign-in and infrastructure).
- **Legal bases.** Contract (GDPR Art. 6(1)(b)) and legitimate interests (Art. 6(1)(f)). You may object to processing based on legitimate interests at any time (Art. 21).
- **Retention.** Kept only as necessary for the purposes above and to meet legal requirements (see Data Retention and Deletion). Push tokens are retained while needed to deliver notifications to your device and are removed when you sign out, disable notifications at OS level, or when the token is rotated/invalidated.
- **Note.** Approximate region (e.g., country/city) may be inferred from IP address for security and localization; this does not use device Location services or background tracking.

Third-party derived information (if you choose to use it)

- If you register/sign in with Google or Facebook, the provider shares basic account information with TMA (e.g., name, email, and an authentication token/ID) so we can create and authenticate your account. We do not receive your password. Processing by Google/Meta is subject to their own privacy policies.

- **Legal bases.** Contract (GDPR Art. 6(1)(b)) to create/manage your account and legitimate interests (Art. 6(1)(f)) for fraud prevention and account security.
- **International transfers & safeguards.** See International data transfers.

3. Purpose of Data Collection and Use

We use your personal data only for the purposes below (see Legal Bases for Processing Personal Data for the applicable bases):

- **Service Delivery:** To operate the Application and the features you choose to use (account creation/sign-in, pairing compatible devices, saving/syncing and displaying measurements with source labels, uploading files, and showing charts/trends).
- **Teleconsultations:** To schedule, connect, and support video consultations you initiate with healthcare professionals.
- **Purchases and Fulfillment:** To facilitate doctor-session and medical-device purchases via TMA-managed e-shops, including identity verification, fraud prevention, customer support, and issuing official invoices/receipts where required by law.
- **Safety Assistance (Location Features):** To process location data only when you opt in (e.g., Send Location/Location Sharing) to assist during emergencies and provide clinical context.
- **Customer Support and Service Communications:** To respond to inquiries, provide service/security/legal notices, and handle requests about your rights.
- **Security and Fraud Prevention:** To protect accounts and our services, detect/prevent abuse, and maintain service integrity (including logging, troubleshooting, crash reporting, and performance monitoring).
- **Compliance and Enforcement:** To comply with legal obligations (e.g., tax/invoicing, record-keeping) and enforce our Terms of Use.
- **Quality and Improvement:** To monitor performance and improve stability and user experience, primarily using device and diagnostic data (e.g., crash/performance metrics). We do not use your health data for advertising or marketing, and we do not sell personal data.

We will use personal data only for the purposes described above. If we intend to use your data for a new, materially different purpose, we will provide notice and, where

required by law, obtain your consent before doing so. If processing is based on legitimate interests, you have the right to object at any time (GDPR Art. 21). We do not make decisions based solely on automated processing that produce legal or similarly significant effects about you (GDPR Art. 22).

4. Data Retention and Deletion

We retain your personal data only for as long as necessary to provide the Application and the features you choose to use, or as required by law. Our primary hosting is in the EU/EEA (Hetzner).

- **While your account is active:** We store your profile, measurements (including their source labels “AI/Device/Manual”), uploaded files, and settings so the app can function as intended. Camera images/video used for AI analysis are processed on-device and are not stored on our servers.
- **Item-level deletion:** You may delete individual measurements from your history at any time; deletions sync across your signed-in devices. (Uploaded files cannot currently be deleted in-app; to request deletion, open a support ticket at <https://support.tma.gr> or contact the DPO at dpo@tma.gr. We will honor eligible GDPR erasure requests by deleting or irreversibly anonymizing the files.)
- **Account deletion / withdrawal of consent:** You can delete your account in Settings → Delete Account. We will permanently delete or irreversibly anonymize personal data we control within a reasonable period after your request, except where we must retain specific data to:
 - comply with legal obligations (e.g., tax/invoicing and statutory record-keeping),
 - resolve disputes, prevent fraud/abuse, enforce our terms, or for the establishment, exercise, or defense of legal claims (kept only for the minimum necessary period), or
 - respect the independent clinical records kept by healthcare professionals you choose to engage (maintained under their own legal/professional obligations and outside TMA’s control).
- If you **cannot access the app**, you can also **request account deletion by opening a support ticket** at <https://support.tma.gr>. We may request information to verify your identity before proceeding. We will act on your request without undue delay and within one month (extendable by up to two

months where necessary, considering complexity and volume), and will permanently delete or irreversibly anonymize data we control, subject to legally required retention.

- **National identifiers (e.g., SSN):** You can remove your identifier via Settings → Manage SSN Consent. Where law requires retention (e.g., invoicing or prescription rules) or to keep transaction records, we retain it only for the applicable statutory/limitation period and then delete or irreversibly anonymize it.
- **Diagnostics and logs:** Limited device and diagnostic data (e.g., crash/performance metrics) used for security and stability is retained for a limited period and then deleted or aggregated. Not used for advertising.
- **Backups:** Deleted data may persist in encrypted backups for a short disaster-recovery window before being overwritten by our backup rotation.

We do not keep personal data longer than necessary. When retention ends, we delete or irreversibly anonymize the data. You can contact our DPO to exercise your rights or ask about specific retention rules that apply to your situation.

5. Data Sharing

We do not sell personal data. We do not share your health data for third-party advertising or marketing. We share data only as described below:

- **Service provision (on our behalf):** We disclose personal data to trusted service providers (processors) who operate our infrastructure and features under our instructions and Data Processing Agreements—for example, EU/EEA hosting (Hetzner) and, where enabled, Google Firebase Authentication/Crashlytics/Performance for sign-in, stability, and security. These providers are not permitted to use your data for their own purposes.
- **Healthcare professionals you choose to engage:** When you initiate a teleconsultation, the minimum necessary information is made available to the contracted healthcare professional to provide the service (see 5.1).
- **At your direction/consent:** When you use features that export or share information (e.g., sharing files or measurements), we disclose the data you choose to the recipients you select.
- **Purchases and fulfillment:** For device/doctor-session purchases via TMA-managed e-shops, we share the minimum necessary data with

payment/fulfillment and invoicing providers to complete the transaction, prevent fraud, and issue official invoices/receipts where required by law.

- **Legal and safety:** We may share data where required by applicable law or a competent authority, or to protect users, prevent fraud/abuse, enforce our terms, or address security incidents.
- **Aggregated/anonymous insights:** We may disclose de-identified or aggregated information that does not identify you.

For international transfers and safeguards (e.g., Standard Contractual Clauses), see International data transfers above. We share data with service providers only to run the app for you, and with clinicians only when you choose to consult them—never for their advertising.

5.1. Data Sharing for Service Provision (Teleconsultations)

- **Who receives data:** Healthcare professionals contracted with TMA and based in Greece (EU/EEA). They access only the minimum necessary information when you initiate a teleconsultation (e.g., profile details you provided, relevant measurements with “AI/Device/Manual” labels, your notes, and any files you explicitly share).
- **How data flows:** Data originates from the ePokratis MedAiConnect mobile application and is securely routed via a TMA-operated teleconsultation platform hosted in the EU/EEA and operated in accordance with GDPR and applicable data-protection laws. Audio/video for live consultations is transmitted for the session and is not recorded by TMA.
- **What clinicians can do:** Through this platform, clinicians can securely access and view your information, prescribe treatments, and make those prescriptions/treatment instructions available in the Application for you to view.
- **Roles under GDPR:** Healthcare professionals act as independent controllers of the clinical record under professional secrecy and their legal/professional obligations. TMA acts as the controller for the app/service and as the provider of the secure teleconsultation platform, and it routes/displays items the clinician provides. Clinicians may retain copies as part of their own medical records (outside TMA’s control).
- **Geography & transfers:** Although the Application is available in many countries, teleconsultation services are delivered by clinicians located in

Greece (EU/EEA), and platform hosting is in the EU/EEA. Some supporting service providers (e.g., Firebase for sign-in/stability) may process limited personal data outside the EU/EEA under approved safeguards (e.g., Standard Contractual Clauses); see International data transfers.

- **No onward use:** Data shared with clinicians is used only to deliver the care you request.
- **Your choice:** You decide whether to start a consultation and what information/files to share during it.

5.2. Data Sharing with Healthcare Professionals

- **Role and purpose:** Healthcare professionals contracted with TMA act as independent controllers of the clinical record under professional secrecy and applicable law. They receive only the minimum necessary information to provide the services you request (e.g., a teleconsultation) and must use it solely for that purpose.
- **Identifiers for prescriptions (SSN):** To issue e-prescriptions or submit to national systems (e.g., EOPYY in Greece), clinicians may need your national identifier. If you have provided an identifier in the Application, TMA will disclose it to the clinician you engage for this purpose. The clinician processes the identifier under their legal obligations and may retain it in their medical records; removing your identifier from TMA does not affect records clinicians must keep under law.
- **Legal and professional obligations:** Clinicians are subject to GDPR, strict confidentiality duties, medical-ethics rules, and professional secrecy under Greek law.
- **Contractual safeguards with TMA:** Access to the TMA-operated teleconsultation platform is governed by contracts requiring (a) use only to deliver care you request; (b) confidentiality; (c) security controls; (d) prompt (without undue delay) breach notification; and (e) no use of your data for advertising/marketing or resale.
- **Security on our platform:** Data is routed over encrypted channels and stored on EU/EEA hosting with encryption in transit and at rest, role-based access controls, and audit logging. TMA monitors platform access and may suspend or terminate a clinician's platform access in case of suspected misuse or non-compliance.
- **What TMA can (and cannot) audit:** TMA can audit platform access and usage. Clinicians may also keep records in their own clinical systems to meet

legal/professional obligations; those systems are outside TMA's operational control and governed by the clinician's own compliance duties.

- **Misuse prohibited:** Any unauthorized access, misuse, or onward disclosure of your personal data is strictly prohibited. Where we detect or are informed of a breach in TMA-controlled systems, we will take appropriate action (e.g., suspend access, notify authorities, and inform affected users where required by law). As independent controllers, clinicians are responsible for any notifications required for incidents in their own systems.

5.3. Consent and Your Controls

- **Consent at sign-up (health data):** When you create an account, you give explicit consent for us to process and sync your health data to your account (including measurements from compatible devices, AI-derived results, and manually entered readings). Numeric results are saved and synced by default so you can view them across your signed-in devices. Camera images/video used for AI analysis are processed on-device and are not uploaded or stored on our servers. You can delete individual readings at any time (deletions sync across your signed-in devices).
- **Optional features that need consent:** We ask for separate consent for Location features (e.g., Send Location / Location Sharing). You can use the app without enabling these features.
- **What isn't based solely on consent:** Some processing is necessary to perform the service (GDPR Art. 6(1)(b)), to meet legal obligations (Art. 6(1)(c)), and to protect security/fraud prevention (legitimate interests, Art. 6(1)(f)). For teleconsultations, clinicians process health data under GDPR Art. 9(2)(h) (health care by professionals under confidentiality).
- **Sharing with clinicians (your action):** When you start a consultation, you instruct us to disclose the minimum necessary information to the contracted healthcare professional so they can provide care. Not used for advertising.
- **How to withdraw or change choices:**
 - **Delete Account:** Settings → Delete Account (removes server-stored data we control, subject to legal retention).
 - **Manage SSN Consent:** Settings → Manage SSN Consent (remove your identifier).
 - **Location:** Settings → Location Sharing → Deny (in-app). You can also revoke the device's Location permission in your OS settings.
 - **Per-item deletion:** Delete individual measurements from History; deletions sync across your signed-in devices.

- **Uninstalling the app:** Uninstalling does not delete your account or server-stored data. Use Settings → Delete Account to remove data stored by TMA.
- **Effect of withdrawal:** Withdrawing consent does not affect the lawfulness of processing carried out before withdrawal. Some data may be retained where required by law (e.g., tax/record-keeping) or for the establishment, exercise, or defense of legal claims. Clinicians may retain records in their own systems under their legal/professional obligations.

5.4. Third-party services and providers

Information you provide directly to third-party providers not owned or operated by TMA is not covered by this Privacy Policy. Please review those providers' privacy policies.

- **Google Play purchases & subscriptions (Android):** Purchases you make through the Application are processed by Google Play Billing (independent provider) and its authorized payment partners. TMA does not access or store your full billing/payment details; these are handled under Google's terms and privacy policies.
- **RevenueCat (subscription management):** We use RevenueCat to manage subscription status and entitlements on TMA's behalf (processor). RevenueCat processes limited purchase metadata (e.g., product identifiers and platform receipts/purchase tokens) to validate entitlements. RevenueCat does not receive full payment card numbers. Processing may occur outside the EU/EEA under appropriate safeguards (e.g., Standard Contractual Clauses); see International data transfers.

This clause does not apply to official TMA eShops or informational websites linked from within the Application, which are owned and operated by TMA and governed by this Privacy Policy. (Where a TMA eShop uses a payment gateway, the gateway processes payment details on TMA's behalf; TMA does not receive full card numbers.)

6. Data Encryption

At ePokratis MedAiConnect, we are committed to protecting the security and confidentiality of your personal data. We employ advanced encryption protocols to ensure your data remains secure in compliance with industry standards. Below are the key security measures implemented in our solution:

Data Encryption at Rest

We encrypt server-stored personal data at rest using AES-256, a trusted and widely recognized standard. This encryption ensures that user data remains protected and inaccessible, even in the event of a physical storage breach.

Independent of any infrastructure-level encryption offered by our hosting provider (Hetzner Online GmbH), all sensitive data stored through our Application is encrypted at the application layer using AES-256.

Encryption in Transit

All data transmitted between the Application and external servers is encrypted using HTTPS/TLS protocols. These protocols establish secure communication channels, protecting your data from interception and ensuring its integrity and confidentiality during transfer.

Client-Side Encryption

Where implemented for selected highly sensitive data, we use client-side encryption. This means your data is encrypted directly on your device before being transmitted to external servers, ensuring that only authorized systems or users with decryption credentials can access it.

Key Management Practices

We use trusted key-management and secret-management practices; where a Key Management Service (KMS) is used, keys are protected via secure secret stores and environment variables. Our key management practices include:

- Protecting keys using secure secret management tools and environment variables.
- Ensuring keys are never hard-coded or exposed in the app's codebase.

Compliance and Certifications

We align our controls with recognized security standards and use hosting providers that maintain relevant certifications, such as:

- **ISO/IEC 27001** (Information Security Management)
- Controls aligned with **ISO/IEC 27017/27018**, where applicable
- **GDPR** (applicable EU data-protection law)

Technical Encryption Measures

Our solution incorporates a comprehensive set of encryption protocols, including:

- **AES-256 Encryption** (for data at rest)
- **TLS (HTTPS) Encryption** (for data in transit)
- **Client-Side Encryption** (where implemented for selected sensitive data)
- **Data Masking and Tokenization** (where appropriate) to further protect sensitive information.

Access Control and Security Rules

We enforce role-based access control (RBAC) through our security rules to ensure that only authorized users can access specific data. This approach helps maintain the integrity and confidentiality of your personal information.

User Responsibility

While we implement robust encryption and security measures, we encourage users to also take the following precautions to protect their data:

- Keep authentication credentials confidential.
- Regularly update passwords to maintain account security.
- Use the Application in secure, trusted environments and avoid sharing sensitive information over public or unsecured networks.

7. Security Measures

TMA is committed to implementing appropriate organizational and technical measures to protect the security of users' personal data, in accordance with applicable data protection laws. These measures are designed to prevent unauthorized access, alteration, loss, or misuse of personal data, considering the state of technology, the nature of the data, and potential risks.

To further ensure the security of your account, users are responsible for safeguarding their login credentials, including passwords, and should take steps to prevent unauthorized access. To the extent permitted by law, TMA is not responsible for misuse of accounts resulting from compromised or shared credentials.

8. User Rights

Users have the right to access, rectify, delete, restrict, port, and object to certain processing of their personal data (GDPR Art. 21). Where available, these rights can be exercised in-app; some items (e.g., certain uploaded files) may require contacting Support or the DPO (see Section 4). Please note that withdrawing consent and/or deleting personal data may prevent TMA from providing some or all services. Deletions are subject to legally required retention (see Section 4).

Users may also withdraw their consent for specific purposes at any time, without affecting the lawfulness of data processing prior to the withdrawal.

Users retain the right to contact the **Hellenic Data Protection Authority (HDPa)** regarding any concerns or complaints about their data privacy. Complaints can be submitted:

- By phone at **+30-210 6475600**
- In writing to **Kifisias 1-3 Avenue, P.C. 115 23, Athens**
- Or via email to contact@dpa.gr.

You may also lodge a complaint with your local supervisory authority, if different from the HDPa.

Children's Privacy. The Application is not intended for individuals under **16** (or the higher age of digital consent in your country). We do not knowingly collect personal data from children under this age. If you believe a child has provided data, contact us and we will delete it as required by law.

9. Changes to Our Privacy Policy

We may update this Privacy Policy to reflect legal, regulatory, or operational changes. Any changes will be reflected in the updated Privacy Policy, which will always be made available within the Application.

If a change materially affects your rights or introduces new purposes, recipients, or legal bases, we will provide prominent notice in the Application and/or by email (where available) before it takes effect and, where required by law, obtain your consent.

Your continued use of the Application after non-material updates constitutes acceptance of the revised Policy. If you do not agree to material changes, you may stop using the Application and delete your account (see Section 4). We encourage

you to review the Policy periodically to stay informed about how your personal data is protected.

10. Contact Information

If you have questions, concerns, or requests about this Privacy Policy or how your personal data is handled, contact us:

Telematic Medical Applications LTD

151 Al. Papanastasiou Avenue, Piraeus, Attica, P.C. 18533, Greece

Phone: +30 211 1165330-2

Email (general): info@tma.gr

Data Protection Officer (DPO): dpo@tma.gr

We will respond as promptly as possible and within one month of receiving your request (extendable by up to two additional months where necessary, in line with GDPR).